

Informe Zero-Trust.

1. De qué hablamos cuando hablamos de Zero Trust

El modelo Zero Trust, según NIST SP 800-207, no es una tecnología, sino un paradigma de diseño:

- Ninguna entidad (usuario, dispositivo, aplicación, flujo de datos) es de confianza por defecto.
- Cada acceso es una decisión individual, continua y dinámica, basada en identidad, contexto y riesgo.¹
- El perímetro ya no es la frontera; el recurso y la identidad lo son.¹

En España, esto se encaja con el Esquema Nacional de Seguridad (ENS), la NIS2, la Directiva DORA y la Agenda España Digital 2025, que exigen un control de riesgo fino sobre activos críticos y servicios públicos.¹²³

2. Indicadores globales de madurez Zero Trust (2025–2026)

Desde 2025, los organismos y centros de investigación hablan de *KPIs de arquitectura* más que de “parches de seguridad”. Algunos indicadores clave:

2.1. Adopción y madurez

- Porcentaje de organizaciones con Zero Trust parcial o total:
Encuestas globales (StrongDM 2025, Tailscale, Okta) señalan que alrededor del 80–85% de las empresas ya tienen Zero Trust en fase de despliegue o consolidado.⁵⁶
- Madurez por modelo CISA (ZTMM v2):
CISA propone cuatro niveles: Traditional → Initial → Advanced → Optimal, medidos sobre cinco pilares: Identidad, Dispositivos, Red, Aplicaciones y Datos, más visibilidad y automatización.⁷⁸
- Encuestas globales (StrongDM 2025, Tailscale, Okta) señalan que alrededor del 80–85% de las empresas ya tienen Zero Trust en fase de despliegue o consolidado.⁵⁶
- CISA propone cuatro niveles: Traditional → Initial → Advanced → Optimal, medidos sobre cinco pilares: Identidad, Dispositivos, Red, Aplicaciones y Datos, más visibilidad y automatización.⁷⁸

Métrica de alto nivel:

1 https://portal.mineco.gob.es/RecursosArticulo/mineco/ministerio/ficheros/210204_Digital_Spain_2025.pdf

2 <https://itcs.vip/en/tendencias-ciberseguridad-espana-2025/>

3 <https://digital-strategy.ec.europa.eu/en/factpages/spain-2025-digital-decade-country-report>

- % de entidades públicas/empresas críticas en España en ZTMM $\geq$ “Advanced” (NIS2 / DORA)
Comparado con UE: Francia, Países Bajos o Alemania ya miden progresos en ZTMM como indicador de cumplimiento.⁹
- Comparado con UE: Francia, Países Bajos o Alemania ya miden progresos en ZTMM como indicador de cumplimiento.⁹

2.2. Eficiencia operativa y resiliencia

- MTDD (tiempo medio de detección) y MTTR (tiempo medio de respuesta):
Organizaciones con granularidad Zero Trust y SIEM-SOAR-UEBA reducen MTDD de 200+ días a unas pocas decenas, y MTTR a horas o menos.¹⁰¹¹
- Reducción de brechas e impacto:
En ambientes maduros se observan caídas de:
alrededor del 40–70% en incidentes por phishing y credenciales comprometidas;
50–60% en ransomware y exfiltración de datos.¹²¹⁰
- Organizaciones con granularidad Zero Trust y SIEM-SOAR-UEBA reducen MTDD de 200+ días a unas pocas decenas, y MTTR a horas o menos.¹⁰¹¹
- En ambientes maduros se observan caídas de:
alrededor del 40–70% en incidentes por phishing y credenciales comprometidas;
50–60% en ransomware y exfiltración de datos.¹²¹⁰
- alrededor del 40–70% en incidentes por phishing y credenciales comprometidas;
- 50–60% en ransomware y exfiltración de datos.¹²¹⁰

Ejemplo de métrica territorial:

- Ratio de incidentes críticos por millón de habitantes (ES vs. UE-27), corregido por nivel de ZTMM en sector público.

3. Métricas específicas del marco Zero Trust (pilares)

Bajo NIST, CISA y marcos de madurez europeos, se articulan cinco pilares con sus indicadores. Aquí van ellos, ya traducidos a lógica de “indicador nacional” para España.

3.1. Pilar: Identidad y acceso

Indicadores de identidad Zero Trust (NIST + CISA):

- % de usuarios con acceso JIT (Just-In-Time) y MFA obligatorio en sistemas críticos.
- Ratio de cuentas con privilegios mínimos frente a cuentas con privilegios elevados: conviene que el 80–90% de las cuentas privilegiadas estén en régimen de “principio del mínimo privilegio”.¹³¹⁴
- Número de accesos bloqueados por políticas dinámicas de riesgo (behaviour-based risk policies).

Comparativa España vs. mundo:

- En España, el uso de MFA y IAM avanzado crece, pero aún está por debajo de media UE en el tejido PYME, según estudios de tendencias 2025.³¹²
- A nivel nacional, un buen indicador sería:
% de entidades críticas (NIS2) que miden el riesgo de acceso por sesión (no solo por login).
- % de entidades críticas (NIS2) que miden el riesgo de acceso por sesión (no solo por login).

3.2. Pilar: Dispositivos y endpoints

Métricas de seguridad orientadas a dispositivos:

- % de dispositivos gestionados (corporativos + BYOD) con políticas de postura de seguridad aplicadas (OS parcheado, EDR, cifrado, etc.).
- Media de dispositivos no gestionados por cada 1.000 usuarios en el sector público.
- Tiempo medio entre la detección de una vulnerabilidad crítica y su parcheo en dispositivos críticos.

Zero-Trust en el ecosistema OT (infraestructuras críticas) implica:

- Número de zonas de seguridad microsegmentadas por planta / centro de datos.
- % de accesos a OT que pasan por gateways de validación continua (no solo firewall).¹⁵¹⁶

3.3. Pilar: Red y microsegmentación

En un país donde la digitalización de empresas aún rezaga frente a infraestructura, la red es un campo fértil de métricas:

- % de tráfico de red inspeccionado en profundidad (capa 7) y cifrado de extremo a extremo.
- Número medio de segmentos de red por unidad de negocio (microsegmentación).
- Movimiento lateral medio tras una brecha: si es bajo, indica que la microsegmentación funciona.¹¹¹⁴

Desde 2025, la **Zero Trust Network Access (ZTNA)** se mide también por:

- % de accesos remotos a aplicaciones críticas que pasan por ZTNA, no por VPN clásica.
- ZTNA es uno de los segmentos de mercado que más crece (decenas de miles de millones de dólares), lo que evidencia su adopción como métrica de red segura.¹⁷¹⁸

3.4. Pilar: Aplicaciones y cargas de trabajo

Aquí se cruza cloud, DevSecOps y resiliencia digital:

- % de aplicaciones nuevas diseñadas “Zero-Trust-by-design” (controles de acceso por API, políticas de autorización por recurso, etc.).
- MTTR de contención de un incidente en la nube tras una alerta de Zero Trust.
- Número de accesos no autorizados bloqueados en API y servicios en la nube.

Para España, donde la migración a la nube avanza, un indicador de nivel nacional puede ser:

- Índice de adopción de Zero Trust en aplicaciones de administración electrónica (e-Gobierno, ayuntamientos, servicios públicos online).⁴²

3.5. Pilar: Datos y protección de la información

- % de datos sensibles (PII, datos críticos de infraestructura) que se clasifican y se aplican políticas de acceso basadas en contexto.
- Número de intentos de acceso a datos sensibles bloqueados por políticas de mínimo privilegio.
- % de exfiltraciones de datos críticos que se evitan gracias a controles de movimiento de datos (DLP) y políticas de acceso.¹⁹¹⁰

A nivel nacional, este indicador puede calibrarse con estudios de confianza digital y ciberseguridad en España, que ya miden percepción de riesgo pero aún no unifican métricas totalmente cuantitativas.⁴

4. Indicadores de ciber-resiliencia y continuidad de negocio

Zero Trust no solo reduce incidentes; cambia la capacidad de recuperación. Métricas clave:

- Tiempo medio de restauración de servicios críticos tras incidente (RTO real vs. RTO planeado).
- % de procesos críticos con microsegmentación y políticas de acceso que permiten aislamiento rápido.
- Reducción de impacto económico medio por incidente (coste de incidente por millón de euros de PIB, corregido por sector).²⁰¹⁰

En España, el marco de **Resiliencia Digital** y la **evolución del Ciberseguro** incorporan, desde 2025, indicadores de Zero Trust como variable de riesgo actuarial:

- Que una empresa tenga pilar de identidad en ZTMM $\geq$ Advanced puede reducir su prima de ciberseguro en un 15–30%, según modelos de riesgo de seguros europeos.²⁰

5. Comparativa España-UE-EE.UU.: algunos ejes de indicadores

Para construir un marco nacional territorial, España puede adoptar o adaptar indicadores paralelos a los de otros países:

Eje de indicador	España (ejemplo de objetivo)	UE promedio (línea de referencia)	EE.UU. / CISA (referencia global)
% de entidades críticas con ZTMM $\geq$ Advanced	$\geq 60\%$ en 2027 ⁷	$\approx 50\text{--}70\%$ según país ⁹	$\geq 70\%$ en agencias federales ⁸
% de accesos remotos a apps críticas vía ZTNA	$\geq 50\%$ en 2025 ¹⁸	$\approx 40\text{--}60\%$ en 2025	$> 60\%$ en empresas grandes ¹⁷
MTTD en ambientes Zero Trust	< 60 días	$< 50\text{--}70$ días	< 40 días en entornos avanzados ¹⁰
% de PYMEs críticas con IAM + MFA	$\geq 40\%$ en 2025 ³	$\approx 30\text{--}50\%$ según estado miembro	$\approx 60\%$ en sector crítico ²¹

Estos valores pueden ajustarse con datos de INCIBE, ENISA y el Informe de la UE sobre estrategias de ciberseguridad nacional, que ya proponen marcos de evaluación basados en KPIs.⁵⁶

6. Propuestas de indicadores “ad hoc” para encuestas / marcos nacionales

Si preparas un cuestionario nacional (por ejemplo, dirigido a CISOs de grandes organizaciones, operadores críticos o ayuntamientos), puedes usar estos ítems como métricas de Zero Trust:

⁵ <https://www.incibe.es/incibe-cert/blog/metodologia-zero-trust-fundamentos-y-beneficios>

⁶ [https://www.enisa.europa.eu/sites/default/files/publications/An evaluation framework for cyber security strategies.pdf](https://www.enisa.europa.eu/sites/default/files/publications/An%20evaluation%20framework%20for%20cyber%20security%20strategies.pdf)

1. Madurez de identidad (NIST / CISA):
Ratio de usuarios con MFA en sistemas críticos (0–100%).
% de accesos sesionales con evaluación de riesgo dinámica (SIEM / UEBA / IAM).
Número de accesos JIT por rol privilegiado al mes.
 2. Dispositivos Zero Trust:
% de dispositivos con políticas de postura de seguridad aplicadas.
Tiempo medio de parcheo de vulnerabilidades críticas (días).
Número de dispositivos no gestionados por cada 1.000 usuarios.
 3. Red y microsegmentación:
% de tráfico inspeccionado en capa 7 y cifrado extremo-a-extremo.
Número de segmentos de red por unidad crítica (ej.: centro de datos, planta industrial).
Proporción de accesos remotos vía ZTNA vs. VPN clásica.
 4. Aplicaciones y datos:
% de datos sensibles con políticas de acceso contextual.
Número de accesos no autorizados bloqueados en la última semana.
% de aplicaciones nuevas “Zero-Trust-by-design” sobre el total de aplicaciones puestas en producción.
 5. Resiliencia y riesgo actuarial:
MTTR de servicios críticos tras incidente (horas).
Reducción de impacto económico por incidente vs. año anterior (%).
Índice de percepción de ciberseguridad Zero Trust en ciudadanos y empresas (Eurobarómetro / paneles nacionales).⁴¹⁹
- Ratio de usuarios con MFA en sistemas críticos (0–100%).
 - % de accesos sesionales con evaluación de riesgo dinámica (SIEM / UEBA / IAM).
 - Número de accesos JIT por rol privilegiado al mes.
 - % de dispositivos con políticas de postura de seguridad aplicadas.
 - Tiempo medio de parcheo de vulnerabilidades críticas (días).
 - Número de dispositivos no gestionados por cada 1.000 usuarios.

- % de tráfico inspeccionado en capa 7 y cifrado extremo-a-extremo.
- Número de segmentos de red por unidad crítica (ej.: centro de datos, planta industrial).
- Proporción de accesos remotos vía ZTNA vs. VPN clásica.
- % de datos sensibles con políticas de acceso contextual.
- Número de accesos no autorizados bloqueados en la última semana.
- % de aplicaciones nuevas “Zero-Trust-by-design” sobre el total de aplicaciones puestas en producción.
- MTTR de servicios críticos tras incidente (horas).
- Reducción de impacto económico por incidente vs. año anterior (%).
- Índice de percepción de ciberseguridad Zero Trust en ciudadanos y empresas (Eurobarómetro / paneles nacionales).⁴¹⁹

7. Espíritu irónico y constructivo: cómo usar este marco

Imagina que el “parable” de Zero Trust es un árbitro de fútbol que nunca da por buenas las tarjetas amarillas, sino que revisa cada jugada con VAR, algoritmos de riesgo y consultas constantes con el VAR-central (SIEM / UEBA). En España, el reto no es “poner árbitros”, sino **medir si el VAR está conectado a todos los estadios y si el sistema avisa antes del gol rival**.

Ahora, te propongo:

- Empezar por un “índice de madurez Zero Trust nacional” que combine los cinco pilares.
- Publicarlo como KPI territorial comparable con la UE, para que no solo cuenten los ataques, sino la capacidad de no confiar nunca, siempre verificar.

242526272829303132333435363738394041424344454647484950515253